Universidad Nacional – Sede Regional Chorotega, Campus Nicoya
Seguridad Informática – Laboratorio 8

El Client Secret de Auth0 vive en Supabase Vault

Estudiante: Frander Carrillo Torres · Fecha: viernes 06 de noviembre de 2026 · Horas en America/Costa_Rica (UTC-6)

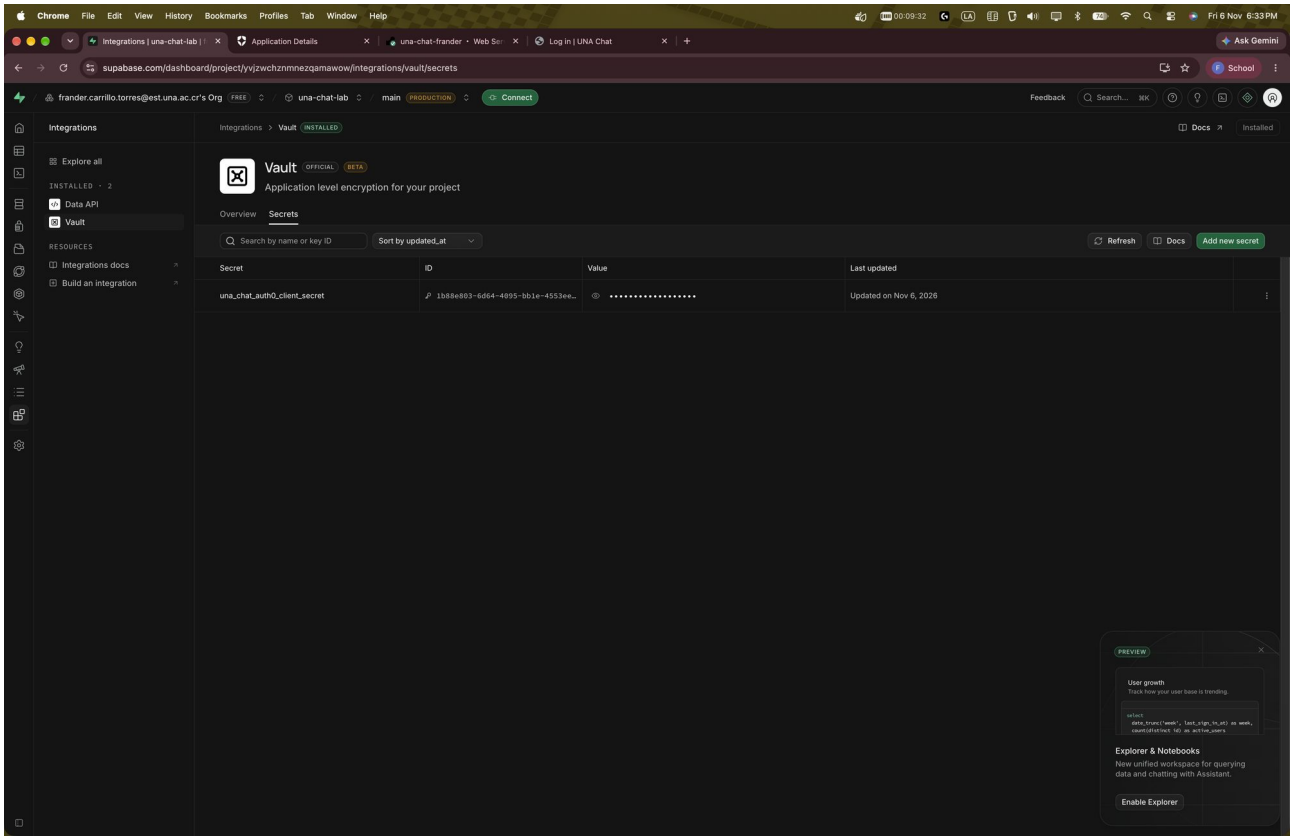
Dato	Valor
Proyecto Supabase	una-chat-lab · ref yvjzwchznmnezqamawow · región ca-central-1 · PostgreSQL 17.11
Tenant Auth0	dev-atpizsyofeuoutpc.us.auth0.com · aplicación UNA Chat
Servicio Render	https://una-chat-frander.onrender.com (plan Free, Docker)
Repositorio / commit	github.com/FranderCT/una-chat-frander · commit desplegado 8f12d6c (rama main)

Ningún valor sensible aparece en este documento: el Client Secret, la contraseña del rol y la conexión completa quedaron fuera de Git, de los logs y de las capturas (los valores en Render están enmascarados).

Bitácora

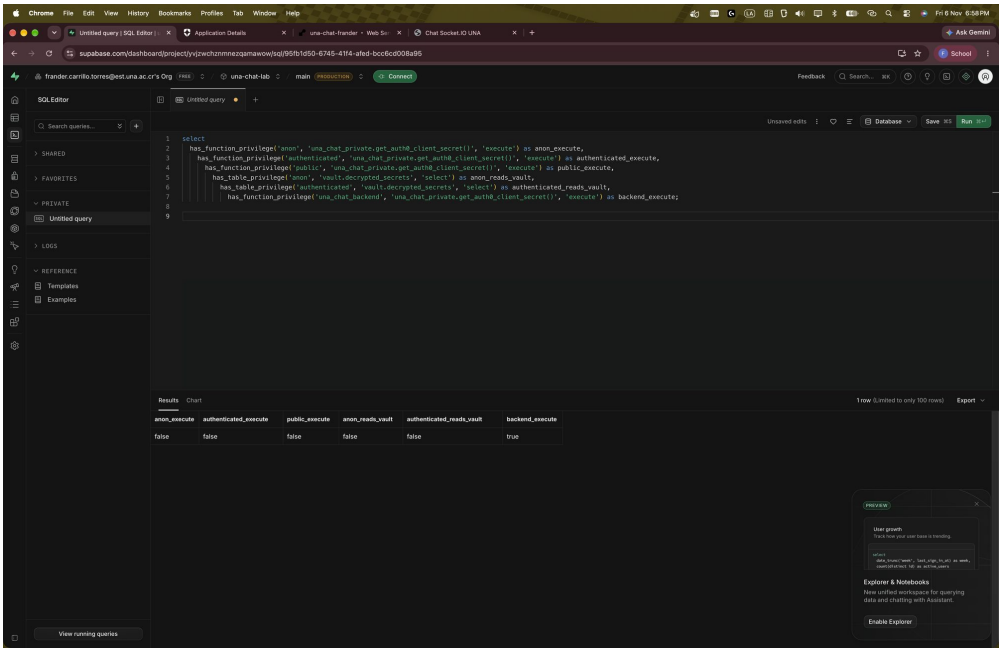
Hora	Etapa	Resultado
17:43	1. Vault	Secreto una_chat_auth0_client_secret creado en Integrations → Vault (longitud 64); valor oculto.
aprox. 17:50	2. Acceso	Rol una_chat_backend creado y script una_chat_vault_access.sql ejecutado: Success.
17:55 / 18:34-18:37	2. Bloqueo	anon y authenticated reciben 42501 al llamar la función; anon recibe 42501 al leer vault.decrypted_secrets.
17:56 / 18:37	3. Lectura	Con el rol de backend secret_length = 64 (mayor que 16).
17:56 / 18:37	3. Membresía	dashboard_is_member = true, pero dashboard_can_use_role = false (ver nota en Permisos).
aprox. 18:00	4. Auth0	Regular Web Application, método Client Secret (Post), tres callbacks, logout y web origins.
18:05	6. Despliegue	Render Live con el commit 8f12d6c (First Deploy).
18:10	6. Sin sesión	GET /auth/config 200; GET /sala 401; GET /auth/login 302 hacia Auth0.
18:27:49	6. Primer login	Ventana privada: se ve el nombre y el botón Cerrar sesión.
-	7. Variable anterior	AUTH0_CLIENT_SECRET nunca existió en Render; la lista final conserva VAULT_DATABASE_URL.
18:29:15	8. Rotación	Client Secret rotado en Auth0.
18:30:05	8. Vault	vault.update_secret con el valor nuevo (verificado por hash, sin mostrarlo).
18:31:35	8. Redeploy	Manual Deploy en Render; arranque 18:31:55: lee Vault y la prueba da invalid_grant.
18:31:51 / 18:31:53	8. /oauth/token	Secreto anterior: HTTP 401 access_denied. Secreto nuevo: HTTP 403 invalid_grant.
18:32:37	8. Login nuevo	Ventana privada nueva: llega a la sala. GET /sala sin cookie: 401 (18:33:01).
18:48-18:50	CICD	Secreto RENDER_DEPLOY_HOOK_URL configurado; workflow CICD pipeline: test success, Deploy success.

1. Vault

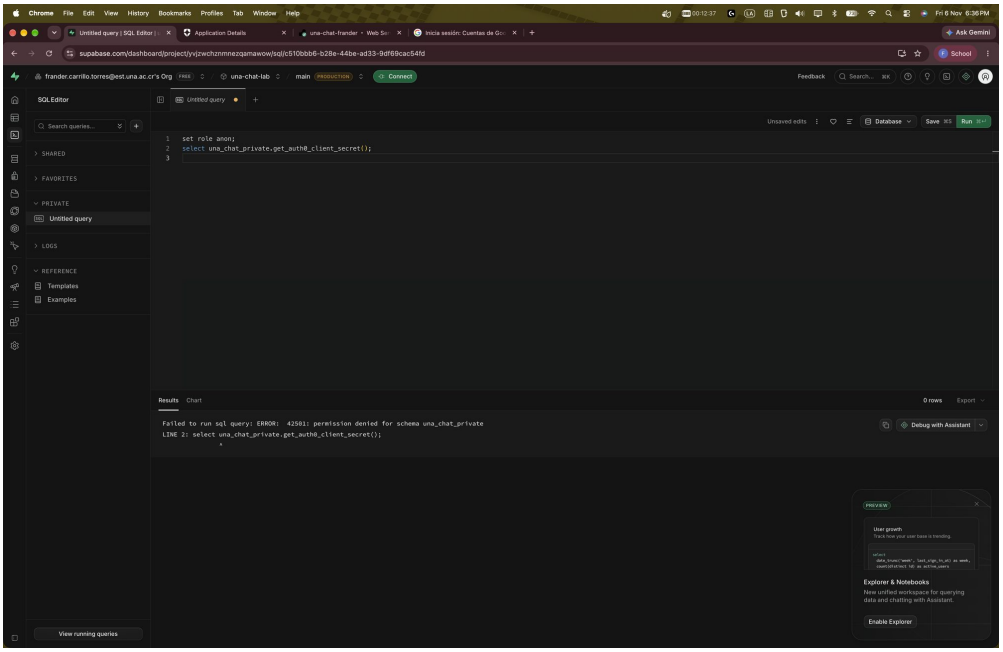


Fila del secreto una_chat_auth0_client_secret en Vault; el nombre se lee y el valor está oculto.

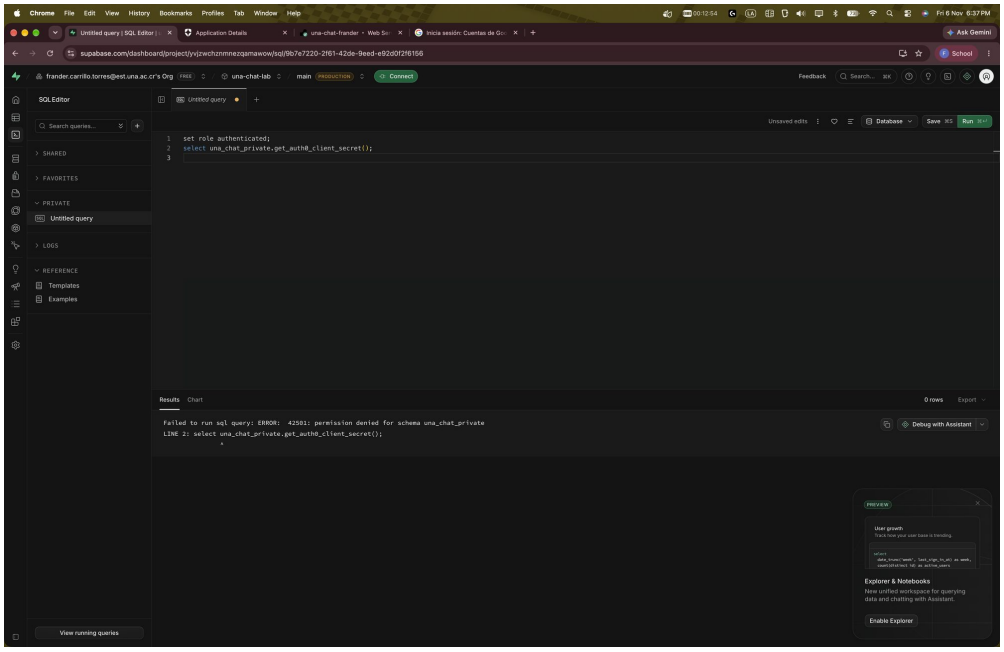
2. Permisos



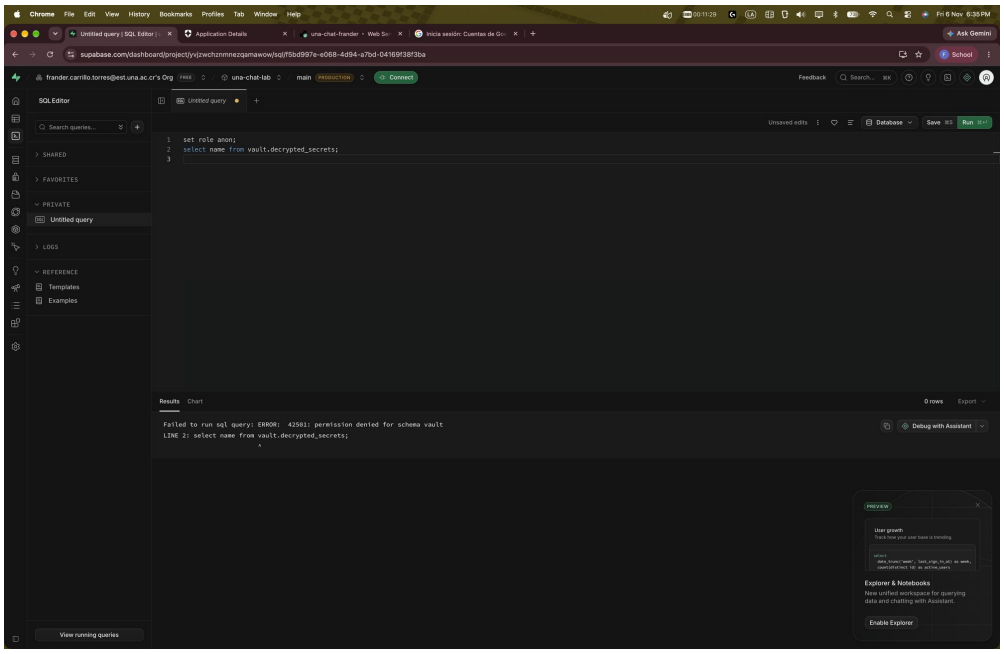
check_vault_privileges.sql: solo backend_execute = true; anon, authenticated y public = false. Hora 18:34:31.



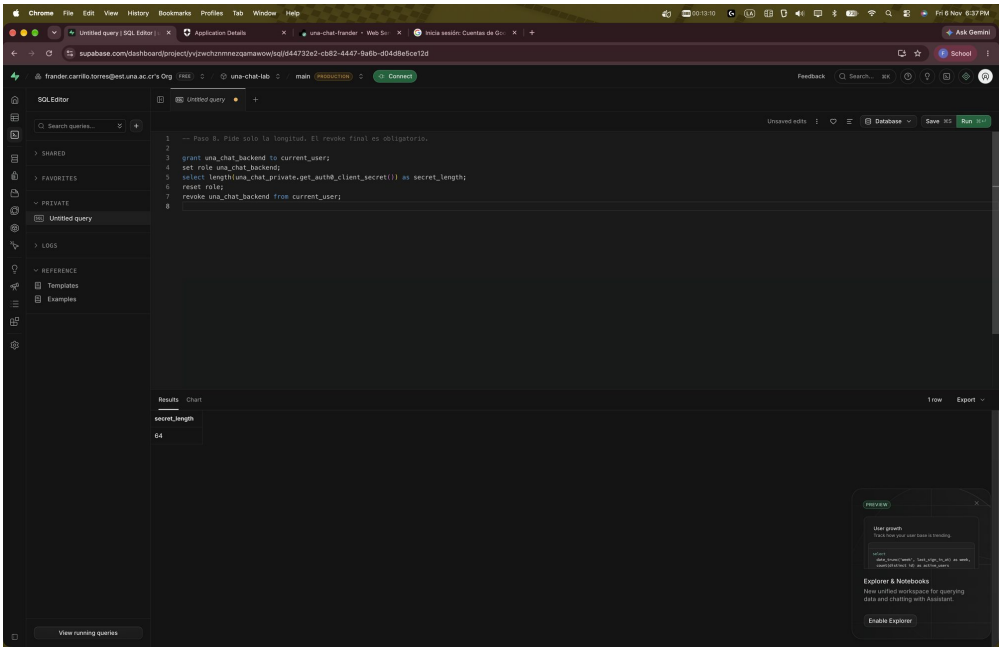
set role anon; select una_chat_private.get_auth0_client_secret(); → error 42501 (permiso denegado). Hora 18:36:53.



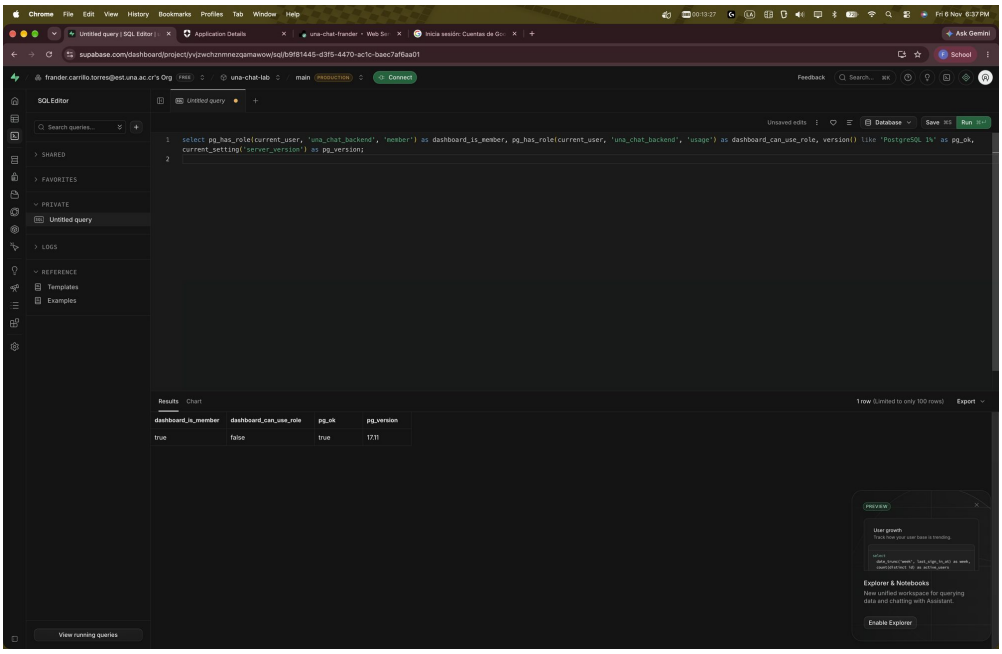
Misma prueba con authenticated → error 42501. Hora 18:37:09.



set role anon; select name from vault.decrypted_secrets; → error 42501 sobre el esquema vault. Hora 18:35:29.



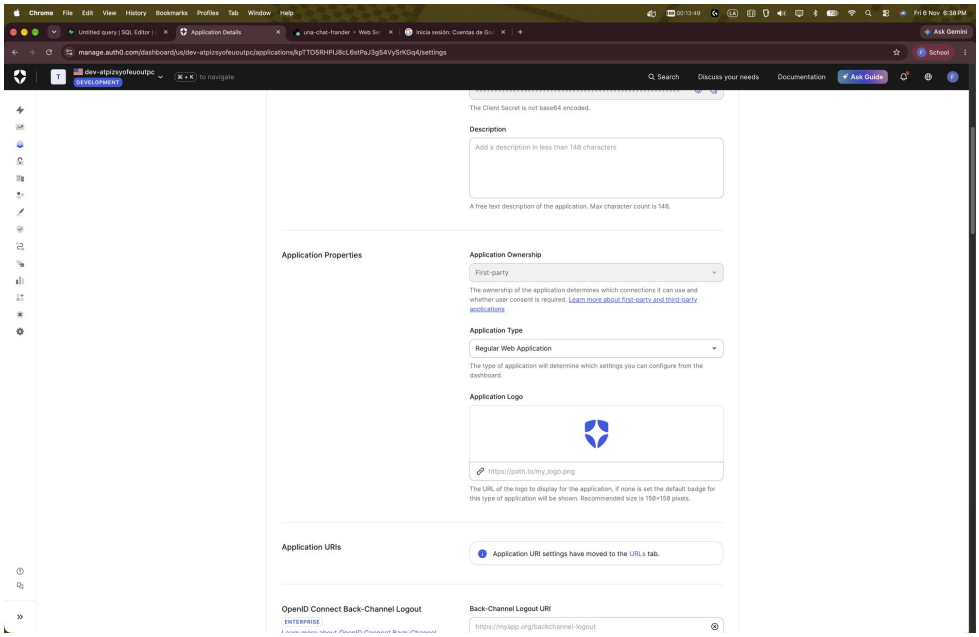
Lectura con el rol del servidor: secret_length = 64 (el valor del secreto nunca se muestra). Hora 18:37:26.



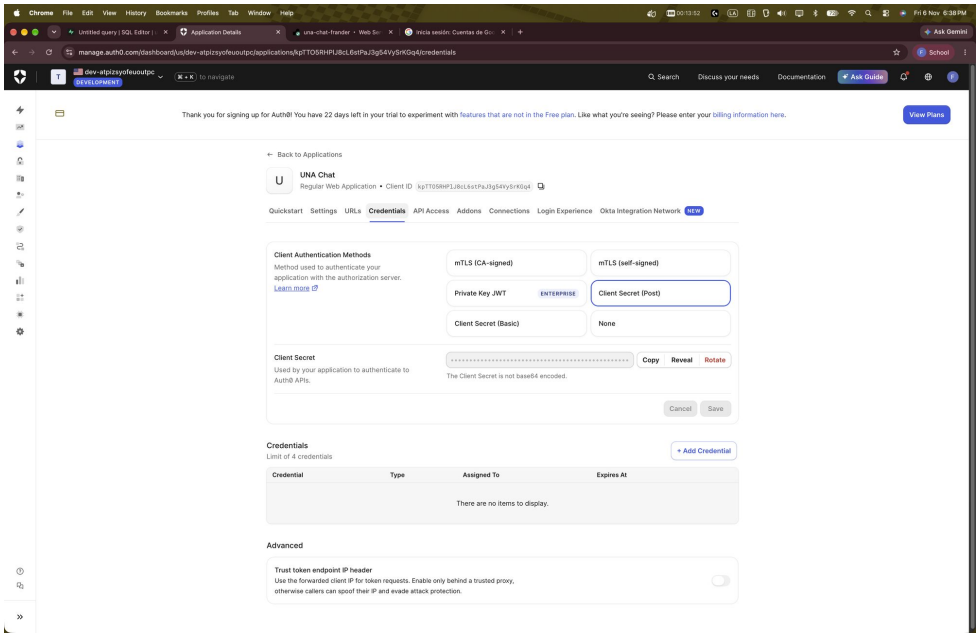
pg_has_role(current_user, una_chat_backend, member) = true; usage = false.

Nota sobre dashboard_is_member. En PostgreSQL 17 de Supabase, al crear un rol el creador (postgres) recibe automáticamente una membresía con admin option otorgada por supabase_admin. El revoke del laboratorio (revoke una_chat_backend from current_user) no la elimina y *revoke ... granted by supabase_admin* devuelve 42501, porque solo ese rol puede revocarla. La membresía no hereda ni permite asumir el rol (inherit_option = false, set_option = false, usage = false): el dashboard no puede ejercer los privilegios del rol sin un grant explícito. El grant temporal de la prueba de longitud sí se revoca al terminar.

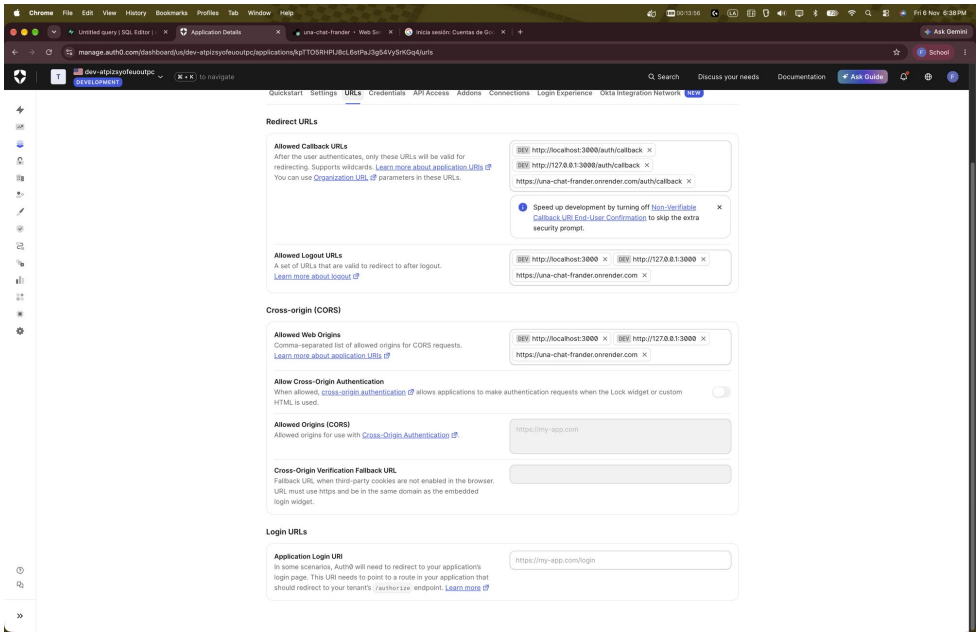
3. Auth0



Application Type: Regular Web Application.

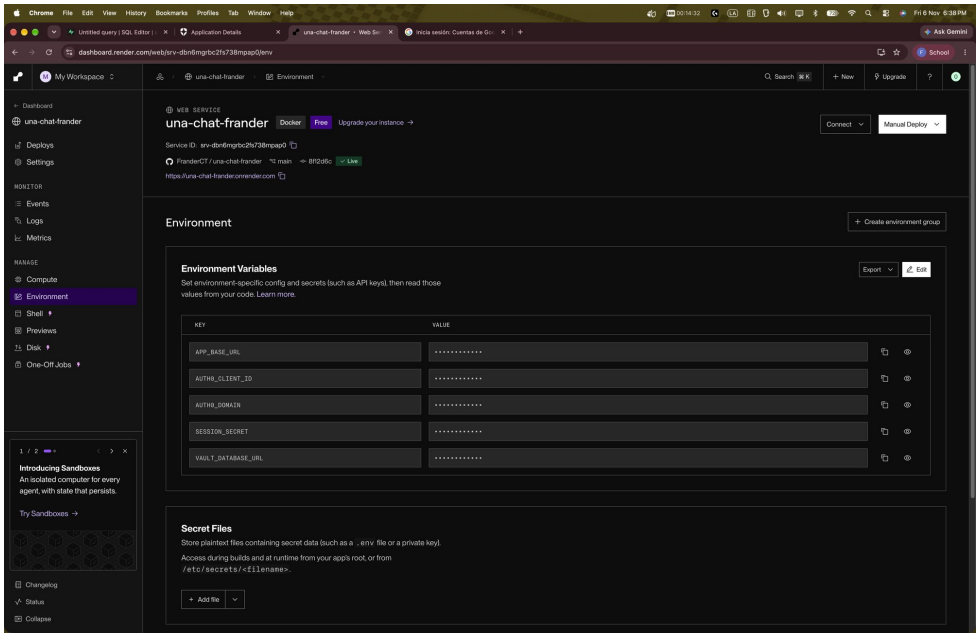


Credentials: método Client Secret (Post); el Client Secret está enmascarado.

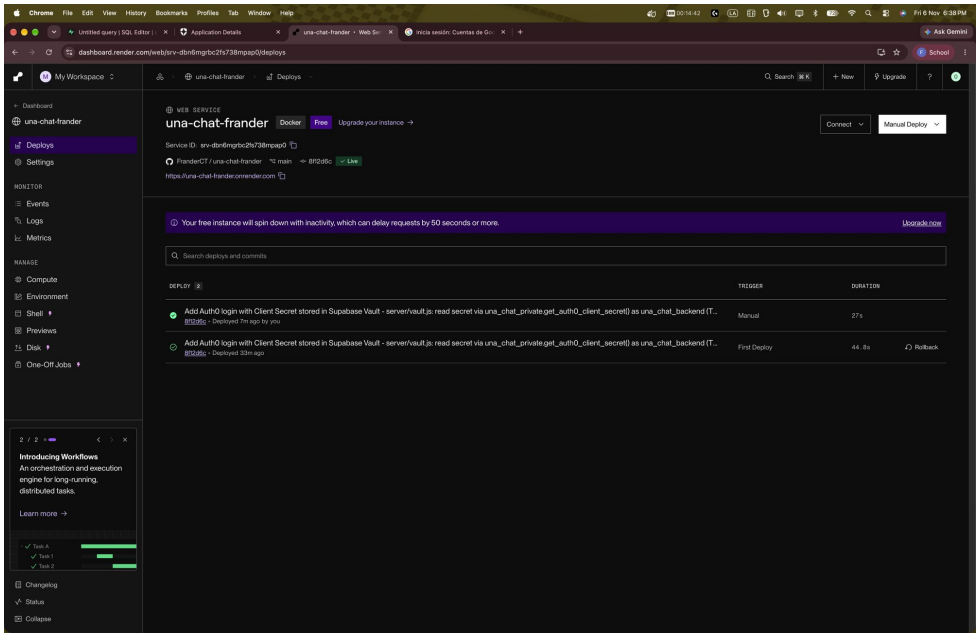


Application URIs: Allowed Callback URLs (localhost:3000, 127.0.0.1:3000 y la URL pública de Render, todas con /auth/callback). Los Allowed Logout URLs y Web Origins llevan los mismos tres orígenes sin la ruta.

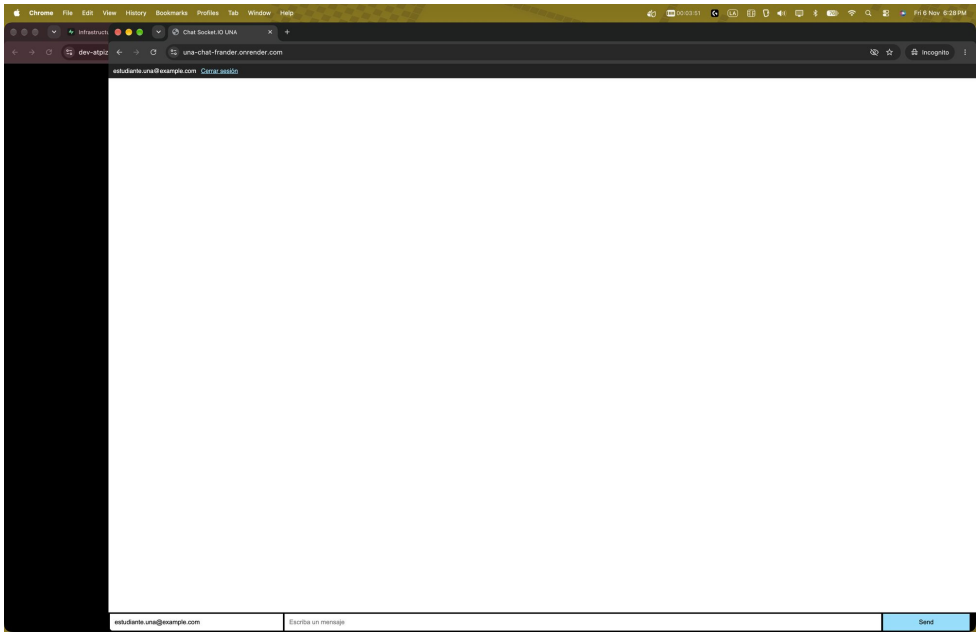
4. Render y login



Environment del servicio: nombres de las variables visibles y valores enmascarados.



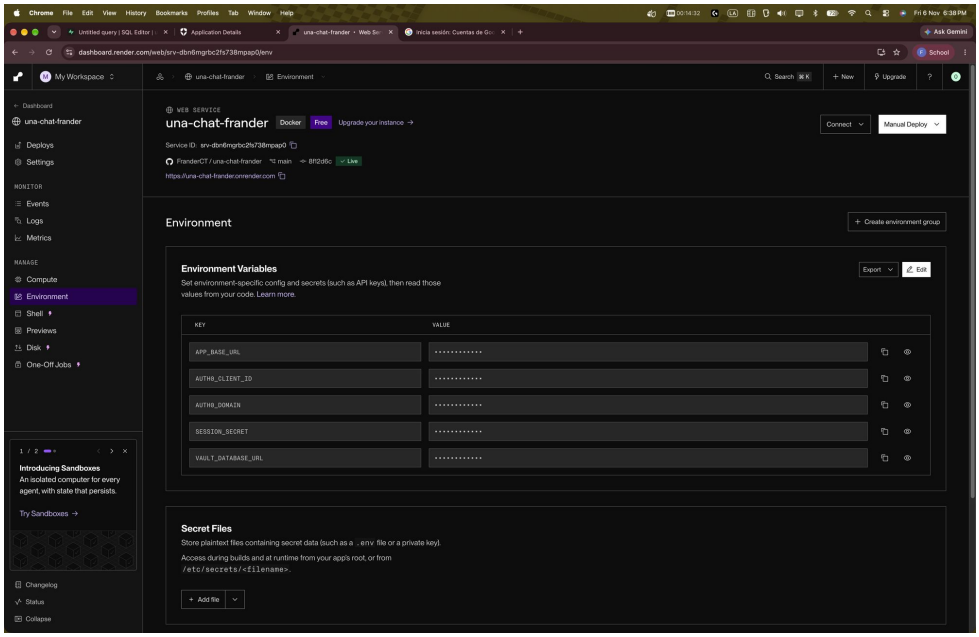
Despliegue Live con el commit 8f12d6c (First Deploy, 44.8 s) desde la rama main.



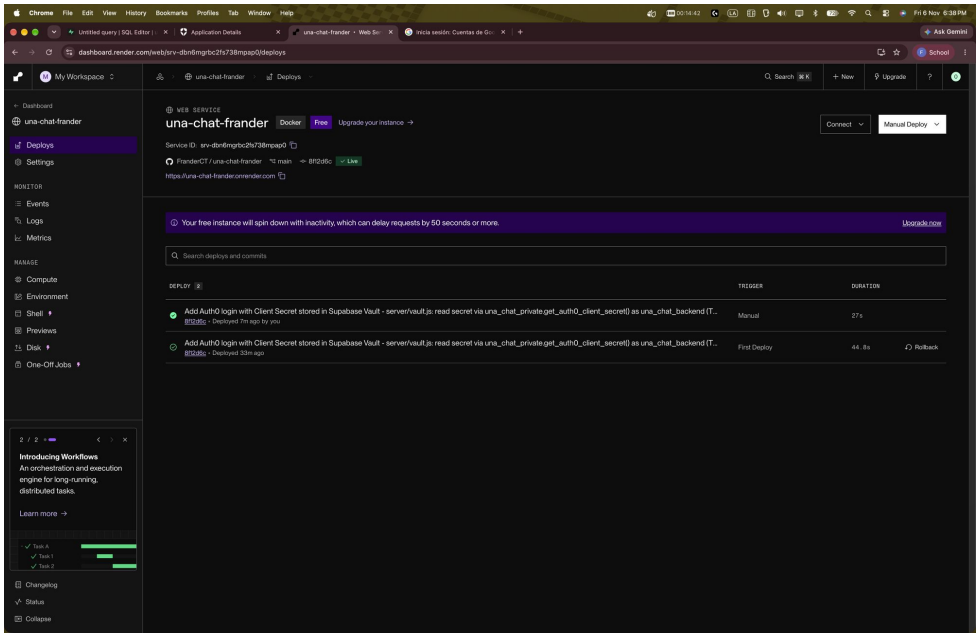
Sesión abierta en una ventana privada (18:27:49): nombre del usuario y botón Cerrar sesión.

5. Retiro de la variable

El servicio en Render nunca tuvo la variable AUTH0_CLIENT_SECRET (el servidor la obtiene de Vault desde el primer despliegue). Lista final de variables: AUTH0_DOMAIN, AUTH0_CLIENT_ID, APP_BASE_URL, VAULT_DATABASE_URL y SESSION_SECRET.



Lista final de variables (VAULT_DATABASE_URL presente; no existe AUTH0_CLIENT_SECRET).



Despliegues posteriores en estado Live; el segundo es el Manual Deploy hecho tras la rotación (18:31:35).

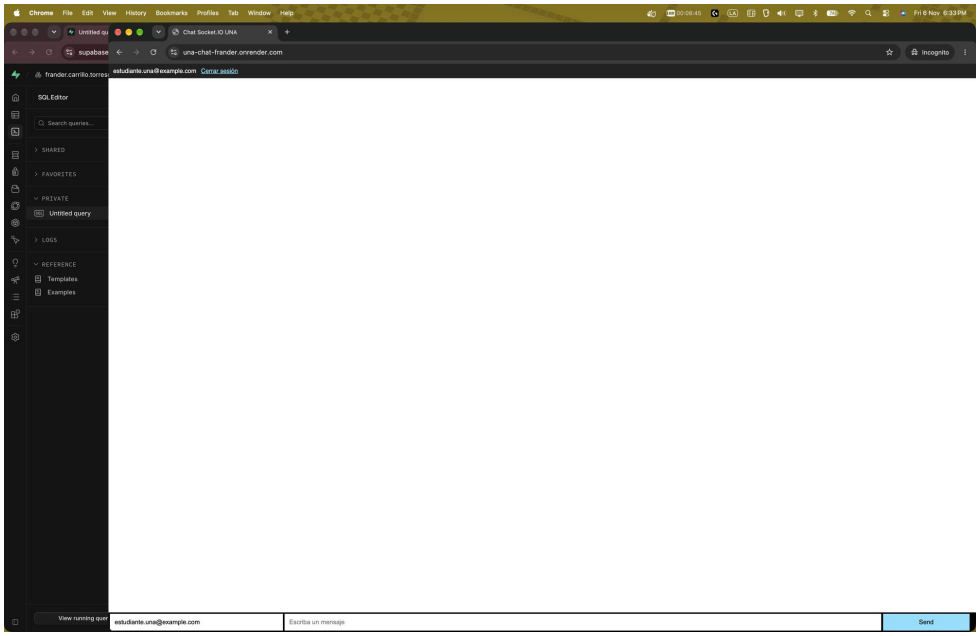
Comprobación sin cookie: GET /sala → 401 (18:33:01).

6. Rotación

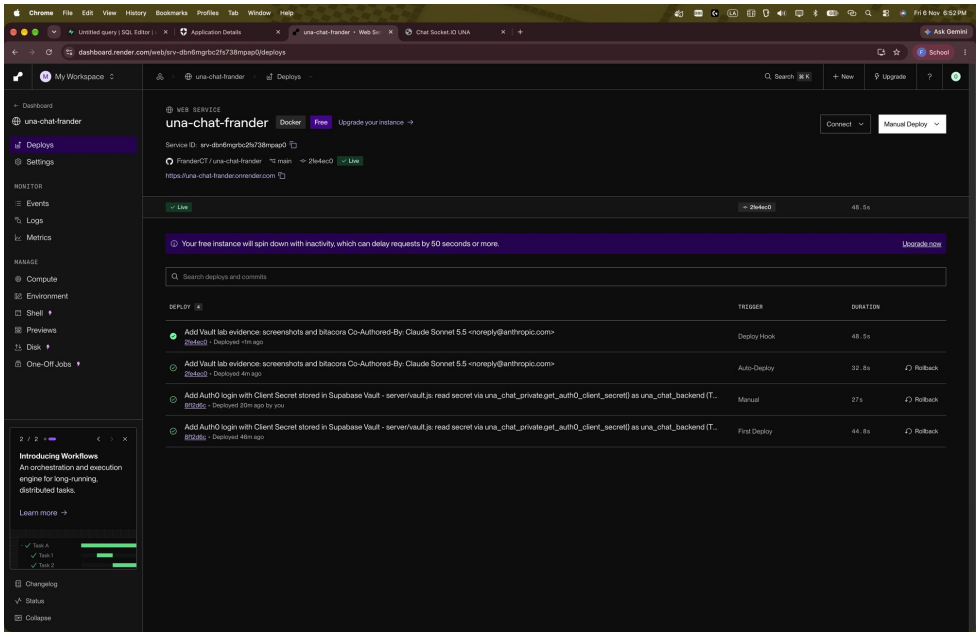
Client Secret rotado en Auth0 a las 18:29:15; Vault actualizado a las 18:30:05 con vault.update_secret; redeploy en Render a las 18:31:35.

Hora	Secreto	HTTP	Campo error
18:31:51	Anterior	401	access_denied
18:31:53	Nuevo	403	invalid_grant

POST https://dev-atpizsyofeuoutpc.us.auth0.com/oauth/token (application/x-www-form-urlencoded) con grant_type=authorization_code, client_id, client_secret (único campo que cambia), code=vault-startup-probe, redirect_uri=https://una-chat-frander.onrender.com/auth/callback y code_verifier de 64 caracteres. Con el secreto nuevo Auth0 acepta la credencial y rechaza el código de prueba (invalid_grant); el secreto anterior es rechazado. El laboratorio esperaba invalid_client para el anterior; este tenant responde 401 access_denied, equivalente (credencial rechazada).



Resultado del login nuevo (18:32:37) en una ventana privada nueva: se llega a la sala.



Deploy disparado por GitHub Actions (CICD pipeline → Deploy) mediante el Deploy Hook de Render, en estado Live.